Exemple. Startup Alpha est une entreprise fictive. Les constats illustrent le format et le niveau de détail d'un rapport réel ; ils ne décrivent aucune entreprise existante.

Due diligence technique et sécurité : Startup Alpha

Paiement marchand par QR et Mobile Money · Dakar et Abidjan · tour d'amorçage de 600 000 € · revue menée du 2 au 13 novembre 2026 · rapport pour le comité d'investissement de [Fonds]

1. Synthèse

Avis : investir sous 3 conditions. Le produit fonctionne et l'architecture tiendra le volume visé à 24 mois. Deux failles peuvent toutefois coûter de l'argent réel ou des données clients avant que l'équipe ne grandisse : elles doivent être corrigées avant le décaissement.

Niveau	Constat	Section
● Critique	Les notifications de paiement Mobile Money ne sont pas vérifiées : un faux paiement peut être enregistré comme réel.	5.1
● Critique	Aucune restauration de sauvegarde n'a jamais été testée ; la dernière sauvegarde complète date de 41 jours.	4.2
● À corriger	Des clés d'API (agrégateur de paiement, envoi de SMS) sont présentes dans l'historique du dépôt de code.	5.2
● À corriger	Un seul développeur connaît et accède à la production.	7.1
● À corriger	Aucune formalité n'a été faite auprès de l'ARTCI ni de la CDP, alors que l'application traite des numéros de téléphone et des historiques d'achat.	6.1
● Solide	Architecture simple (une API, une base PostgreSQL, une file de tâches), adaptée à 50 000 commerçants actifs.	3
● Solide	Le mode hors-ligne de l'application marchande est bien conçu : pas de doublon de vente constaté lors de nos tests.	3

2. Conditions avant le décaissement

1. **Vérifier la signature de chaque notification de paiement** et refuser celles qui ne sont pas signées (effort estimé : 2 jours).
2. **Restaurer une sauvegarde complète dans un environnement de test**, chronométrer la reprise et automatiser une sauvegarde quotidienne (3 jours).
3. **Révoquer et remplacer toutes les clés exposées**, puis les déplacer dans un coffre de secrets (1 jour).

Nous pouvons vérifier ces trois points en une demi-journée, sur preuves, avant la signature.

3. Architecture et capacité à grandir

Une API (Python), une base PostgreSQL gérée, une file de tâches pour les notifications, deux applications Flutter (marchand et client). Le tout est hébergé chez un fournisseur cloud en Europe. Les requêtes les plus lourdes (rapports quotidiens) passent par des index adaptés ; à 10 fois le volume actuel, seul le calcul des rapports demandera d'être déplacé dans une tâche de fond.

4. Infrastructure et exploitation

4.1 Déploiement

Déploiement automatique depuis la branche principale, tests automatisés exécutés à chaque modification (couverture de 58 %). Pas d'environnement de préproduction : les changements arrivent directement en production.

4.2 Sauvegardes

● **Critique**

Les sauvegardes automatiques du fournisseur sont activées, mais la conservation est de 7 jours et aucune restauration n'a été testée. Une sauvegarde manuelle complète date du 3 octobre. Une suppression accidentelle découverte après une semaine serait aujourd'hui irréversible.

4.3 Coûts

Environ 410 € par mois pour 3 200 commerçants actifs. Le poste qui croîtra le plus vite est l'envoi de SMS (61 % du coût) : à surveiller dans le plan d'affaires.

5. Sécurité

5.1 Notifications de paiement

● Critique

Le point d'entrée qui reçoit les confirmations de paiement de l'opérateur ne vérifie pas la signature de la requête. Toute personne connaissant l'adresse peut envoyer une fausse confirmation, que l'application enregistre comme un paiement reçu et sur laquelle elle crédite des points de fidélité. Nous l'avons constaté en lisant le code, sans l'exploiter.

5.2 Secrets

● À corriger

Trois clés apparaissent dans l'historique du dépôt (agrégateur de paiement, SMS, stockage de fichiers). Elles ont été retirées du code actuel mais restent valides.

5.3 Accès

Comptes nominatifs sur le cloud, mais sans double authentification pour deux des trois comptes. Le compte administrateur de l'application est partagé entre le fondateur et le développeur.

5.4 Dépendances

Quatre bibliothèques ont des vulnérabilités connues, dont une de gravité élevée (traitement des fichiers envoyés). Mise à jour simple, sans changement de code attendu.

6. Protection des données

6.1 Formalités

● À corriger

L'application traite des numéros de téléphone, des historiques d'achat et une géolocalisation approximative de commerçants en Côte d'Ivoire et au Sénégal. Aucune formalité préalable n'a été accomplie auprès de l'ARTCI (loi n° 2013-450) ni de la CDP (loi n° 2008-12). L'hébergement en Europe constitue un transfert de données hors du pays, qui peut nécessiter une autorisation. À faire confirmer par un conseil juridique local.

6.2 Consentement

Le consentement des clients au programme de fidélité est recueilli et horodaté ; il peut être retiré depuis l'application. Bon point à conserver.

7. Équipe et propriété

7.1 Personne clé

À corriger

Un développeur salarié a écrit 87 % du code et détient seul les accès de production. Pas de documentation d'exploitation. Nous recommandons un second accès d'urgence, détenu par le fondateur, et une procédure écrite de reprise.

7.2 Propriété

Le dépôt de code, les comptes cloud et les comptes des stores appartiennent à la société. Le nom de domaine est enregistré au nom personnel du fondateur : à transférer.

7.3 Licences

Aucune licence incompatible avec un usage commercial fermé n'a été trouvée.

8. Plan de corrections

Correction	Quand	Effort
Vérifier la signature des notifications de paiement	Avant décaissement	2 jours
Tester une restauration, sauvegarde quotidienne de 30 jours	Avant décaissement	3 jours
Révoquer et remplacer les clés exposées	Avant décaissement	1 jour
Double authentification sur tous les comptes cloud	Sous 30 jours	½ jour
Mettre à jour les 4 dépendances vulnérables	Sous 30 jours	1 jour
Formalités ARTCI et CDP, avis sur le transfert de données	Sous 90 jours	Conseil juridique
Accès d'urgence et procédure de reprise écrite	Sous 90 jours	2 jours
Environnement de préproduction	Sous 6 mois	3 jours

9. Périmètre et limites

Accès en lecture seule au dépôt de code, à la console cloud et à l'interface d'administration, du 2 au 13 novembre 2026 ; entretien de 90 minutes avec le fondateur et le développeur. Tests de sécurité non intrusifs uniquement : aucun test d'intrusion, aucune donnée client consultée. Ce rapport décrit l'état du système à ces dates ; il n'est pas un avis juridique.